

FACULTAD DE ESTADÍSTICA E INFORMÁTICA  
Universidad Veracruzana — Cómputo en la Nube

Proyecto Final - Computo en la Nube

Integrantes:  
Turan Ozbek  
Abraham Nuñez Sanchez  
Rafael Alejandro Diaz Rangel  
Javier Patiño Gonzales

Clínica FEI+ · Microsoft Azure

|                         |                                                     |
|-------------------------|-----------------------------------------------------|
| Proveedor de nube       | Microsoft Azure — Región Mexico Central (Querétaro) |
| Suscripción             | Azure for Students (nivel gratuito / bajo costo)    |
| Grupo de recursos       | rg-clinica-fei                                      |
| Evidencias documentadas | 15 capturas de pantalla del entorno en operación    |
| Fecha de implementación | Junio 2026                                          |

|                                                                                       |    |
|---------------------------------------------------------------------------------------|----|
| 1. Análisis de riesgo.....                                                            | 4  |
| 1.1. Activos de Información Críticos.....                                             | 4  |
| 1.2. Matriz de Riesgos.....                                                           | 4  |
| 1.3. Priorización y Justificación.....                                                | 5  |
| 2. Propuesta Fundamentada.....                                                        | 6  |
| 2.1. Justificación del Proveedor: Microsoft Azure.....                                | 7  |
| 2.2. Estrategia de Migración — Coexistencia.....                                      | 7  |
| 3. Propuesta de Arquitectura.....                                                     | 8  |
| 3.1. Diagrama de Arquitectura.....                                                    | 8  |
| 3.2. Descripción general de la arquitectura propuesta.....                            | 9  |
| Conectividad entre sedes.....                                                         | 9  |
| Gestión de identidades y control de acceso.....                                       | 10 |
| Protección de datos almacenados.....                                                  | 11 |
| - Azure SQL Database.....                                                             | 11 |
| - Azure Blob Storage.....                                                             | 11 |
| - Gestión de claves criptográficas.....                                               | 11 |
| - Auditoría y trazabilidad.....                                                       | 12 |
| - Intercambio seguro con aseguradoras.....                                            | 13 |
| Evolución propuesta para producción.....                                              | 13 |
| 4. Modelo de Responsabilidad Compartida.....                                          | 14 |
| 4.1. Tabla de Responsabilidad Compartida.....                                         | 14 |
| 4.2. Implicaciones Regulatorias — LFPDPPP y NOM-024-SSA3.....                         | 15 |
| 4.3. Conclusión Regulatoria.....                                                      | 16 |
| 5. Fase de Implementación.....                                                        | 16 |
| 5.1. Los tres hallazgos de la auditoría.....                                          | 17 |
| 5.2 Alcance del prototipo.....                                                        | 17 |
| 6. Evidencias de Implementación.....                                                  | 17 |
| 6.1. Evidencia 1 — Grupo de recursos con la infraestructura completa.....             | 17 |
| 6.2. Evidencia 2 — Cifrado de datos transparente (TDE) en la base de expedientes..... | 19 |
| 6.3. Evidencia 3 — Almacén de claves (Azure Key Vault).....                           | 20 |
| 6.4. Evidencia 4 — Auditoría de Azure SQL habilitada hacia Log Analytics.....         | 22 |
| 6.5. Evidencia 5 — Área de trabajo de Log Analytics operativa.....                    | 24 |
| 6.6. Evidencia 6 — Contenedor privado de imágenes de laboratorio.....                 | 25 |
| 6.7. Evidencia 7 — Política de inmutabilidad WORM (730 días).....                     | 26 |
| 6.8. Evidencia 8 — Prueba de acceso anónimo denegado.....                             | 27 |
| 6.9. Evidencia 9 — Grupos de seguridad asignados por rol en Microsoft ID.....         | 28 |
| 6.10. Evidencia 10 — Autenticación multifactor (MFA) en acción.....                   | 30 |
| 6.11. Evidencia 11 — Registro de actividad con trazabilidad completa.....             | 32 |
| 6.12. Evidencia 12 — Intercambio controlado con aseguradoras mediante token SAS.....  | 33 |
| 6.12. Evidencia 13 — Costo de la infraestructura.....                                 | 35 |
| 7. Continuidad Operativa — Requisito 3.1.....                                         | 35 |
| 7.1 El problema original: un servidor que no podía apagarse... y se apagaba.....      | 35 |
| 7.2 Cómo lo resuelve Azure: ya no existe "el servidor".....                           | 36 |
| 7.3 Nota honesta del prototipo: el evento "Pause Databases".....                      | 36 |

|                                                                          |    |
|--------------------------------------------------------------------------|----|
| 7.4 Continuidad durante la migración: coexistencia y escritura dual..... | 37 |
| 8. Matriz de Cumplimiento — Hallazgos vs. Evidencias.....                | 37 |
| 8.1 Limitaciones documentadas del prototipo.....                         | 38 |
| 8.2 Conclusión.....                                                      | 39 |

---

# 1. Análisis de riesgo

Este análisis identifica los activos de información críticos de Clínica FEI+, las amenazas que los afectan, las vulnerabilidades actuales en su infraestructura y el impacto potencial para el negocio. La priorización sigue la metodología de  $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$ .

## 1.1. Activos de Información Críticos

| Activo                                   | Clasificación | Justificación de criticidad                                       |
|------------------------------------------|---------------|-------------------------------------------------------------------|
| Expedientes clínicos electrónicos        | Crítico       | Privacidad del paciente, obligación legal (LFPDPPP, NOM-024-SSA3) |
| Imágenes y estudios de laboratorio       | Crítico       | Diagnóstico médico, convenios con aseguradoras                    |
| Sistema de agendamiento de citas         | Alto          | Continuidad operativa (420 consultas/día)                         |
| Sistema de facturación (×4 sedes)        | Alto          | Ingresos anuales >\$45M MXN, reportes fiscales                    |
| Red de comunicación inter-sedes          | Alto          | Coordinación entre Xalapa, Veracruz, Coatepec, Orizaba            |
| Credenciales de acceso (médicos/admin)   | Crítico       | Control de acceso a información de pacientes                      |
| Integración con aseguradoras (FTP)       | Alto          | 28% de ingresos en riesgo por convenio principal                  |
| Servidor físico central (Xalapa, 9 años) | Crítico       | Punto único de falla para las 4 sedes                             |

## 1.2. Matriz de Riesgos

| ID | Riesgo | Vulnerabilidad | Amenaza / Impacto | Impacto | Prob. | Nivel |
|----|--------|----------------|-------------------|---------|-------|-------|
|----|--------|----------------|-------------------|---------|-------|-------|

|             |                                           |                                           |                                             |         |       |                |
|-------------|-------------------------------------------|-------------------------------------------|---------------------------------------------|---------|-------|----------------|
| <b>R-01</b> | Transmisión de expedientes sin cifrado    | Servidor legado + red interna abierta     | Interceptación de datos entre sedes         | Crítico | Alta  | <b>Crítico</b> |
| <b>R-02</b> | Ausencia de auditoría de acceso           | Sin sistema de logging activo             | Imposibilidad de responder ante incidente   | Crítico | Alta  | <b>Crítico</b> |
| <b>R-03</b> | Estudios accesibles sin autenticación     | NAS sin control de acceso                 | Exposición masiva de datos de pacientes     | Crítico | Alta  | <b>Crítico</b> |
| <b>R-04</b> | Servidor de 9 años, sin HA                | Hardware obsoleto sin redundancia         | Caída de los 4 sistemas de sedes            | Crítico | Media | <b>Alto</b>    |
| <b>R-05</b> | VPN inoperante desde 2022                 | Proveedor cerró, sin sustituto            | Acceso remoto inseguro de médicos           | Alto    | Alta  | <b>Crítico</b> |
| <b>R-06</b> | Backups manuales e irregulares            | Proceso manual sin verificación           | Pérdida permanente de datos ante falla      | Crítico | Alta  | <b>Crítico</b> |
| <b>R-07</b> | FTP con credenciales compartidas          | Protocolo sin cifrado, creds únicas       | Robo de datos, acceso no autorizado externo | Alto    | Alta  | <b>Alto</b>    |
| <b>R-08</b> | Sistema de citas sin mantenimiento (2019) | Sin parches de seguridad 7+ años          | Explotación de vulnerabilidades conocidas   | Alto    | Alta  | <b>Alto</b>    |
| <b>R-09</b> | Comunicación por WhatsApp personal        | Datos clínicos en dispositivos personales | Fuga de información, incumplimiento LFPDPPP | Alto    | Alta  | <b>Alto</b>    |
| <b>R-10</b> | 4 sistemas de facturación sin integrar    | Silos operativos por sede                 | Errores contables, pérdida de información   | Medio   | Media | <b>Medio</b>   |

### 1.3. Priorización y Justificación

Los riesgos han sido priorizados con base en tres criterios: (1) hallazgos detectados durante la auditoría de cumplimiento, (2) impacto financiero directo sobre el convenio del 28% de ingresos y (3) exposición legal ante la LFPDPPP y NOM-024-SSA3.

- **Prioridad 1 — Inmediata (0-30 días): R-01, R-02, R-03, R-05, R-06**
  - Estos cinco riesgos corresponden exactamente a los hallazgos críticos de la auditoría. Sin resolverlos, el convenio con la aseguradora —que representa \$12.6M MXN anuales— no será renovado. Además, la exposición a sanciones por LFPDPPP puede alcanzar hasta \$19.2M MXN según el artículo 65.
- **Prioridad 2 — Corto plazo (30-90 días): R-04, R-07, R-08**
  - El servidor de 9 años representa un punto único de falla que deja a las cuatro sedes sin operación ante cualquier falla de hardware. El FTP sin cifrado y el sistema de citas sin parches representan vectores de ataque activos con exploits públicos disponibles.
- **Prioridad 3 — Medio plazo (90-180 días): R-09, R-10**

- El uso de WhatsApp personal y la desintegración de sistemas de facturación son problemas de gobernanza que deben atenderse en el plan de transformación, pero no representan la crisis inmediata de cumplimiento.

## 2. Propuesta Fundamentada

La siguiente tabla mapea cada requisito de negocio con los riesgos identificados y las soluciones técnicas propuestas en Azure, justificando la decisión en términos de negocio y cumplimiento regulatorio.

| Requisito de Negocio                                           | Riesgo(s)                                     | Solución Azure Propuesta                                                                                                                                                                                        | Justificación de Negocio                                                                             |
|----------------------------------------------------------------|-----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
| <b>REQ-01</b> Continuidad operativa(máx. 4h interrupción)      | R-04(Servidor único)                          | Azure SQL Managed Instance con geo-replicación + Azure Availability Zones. Garantiza RTO < 4h y RPO < 30 min. Cada sede conectada mediante Azure ExpressRoute o VPN Gateway con failover automático.            | Alta disponibilidad integrada (99.99% SLA), failover automático, sin gestión de hardware físico      |
| <b>REQ-02</b> Control de acceso por rol(médico-paciente-admin) | R-03, R-05(Sin autenticación, VPN inoperante) | Microsoft Entra ID (Azure AD) con RBAC granular + Conditional Access. Roles: Médico General, Especialista (cardiología, ginecología, etc.), Administrativo, Auditor. MFA obligatorio para acceso a expedientes. | Cumple NOM-024-SSA3 (control de acceso), LFPDPPP (acceso solo a titulares autorizados)               |
| <b>REQ-03</b> Trazabilidad completa(2 años, inmutable)         | R-02(Sin auditoría)                           | Microsoft Sentinel + Azure Monitor Logs con retención de 2 años en Azure Storage (WORM – Write Once Read Many). Logs firmados digitalmente; ningún administrador puede eliminarlos.                             | Responde a las 3 preguntas de auditoría: quién, qué, cuándo y desde dónde                            |
| <b>REQ-04</b> Protección en tránsito y reposo                  | R-01, R-06(Sin cifrado, backups manuales)     | TLS 1.3 para todo tráfico. Azure Disk Encryption (ADE) + Azure Key Vault para claves. Azure Backup automatizado con retención de 30 días y pruebas de restauración programadas.                                 | Elimina el hallazgo crítico #1 de auditoría; cifrado gestionado por Azure, no por el técnico interno |

|                                                  |                              |                                                                                                                                                                                               |                                                                                 |
|--------------------------------------------------|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>REQ-05Integración segura con aseguradoras</b> | <b>R-07(FTP sin cifrado)</b> | Azure API Management como gateway controlado. Reemplaza el FTP con APIs REST sobre HTTPS con autenticación OAuth 2.0. Cada aseguradora tiene credenciales únicas y auditoría por transacción. | Elimina credenciales compartidas; cada intercambio queda registrado en Sentinel |
|--------------------------------------------------|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|

## 2.1. Justificación del Proveedor: Microsoft Azure

Se seleccionó Microsoft Azure sobre otros proveedores por las siguientes razones técnicas y de negocio:

- Residencia de datos en México: Azure cuenta con la región Mexico Central (Querétaro), cumpliendo el requisito de la aseguradora sobre datos en territorio mexicano.
- Certificaciones para salud: Azure cuenta con certificaciones ISO 27001, ISO 27799 (salud), HIPAA BAA e HITRUST CSF, alineadas con NOM-024-SSA3.
- Microsoft Entra ID: Integración nativa con el ecosistema de identidades más usado en el sector salud en México, facilitando federación con los sistemas de las aseguradoras.
- Costo inicial en Free Tier: Los servicios de prototipo (Azure Free Account) cubren Azure AD Free, 5GB Blob Storage, SQL Database (250GB), y 12 meses de servicios básicos.
- Soporte para técnico no especializado: Azure Portal y Azure Policy permiten gestión declarativa sin requerir experiencia en scripting o DevOps avanzado.

## 2.2. Estrategia de Migración — Coexistencia

La migración se realizará en tres fases para garantizar continuidad operativa y cumplir el plazo de 6 meses de la aseguradora:

| Fase          | Período   | Actividades                                                                                                                    | Entregable Auditoría                     |
|---------------|-----------|--------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|
| <b>Fase A</b> | Meses 1-2 | Configurar Azure AD + MFA, desplegar VPN Gateway, habilitar cifrado TLS en servidor actual, activar Azure Monitor para logging | Resuelve R-01, R-02, R-05 ante auditoría |

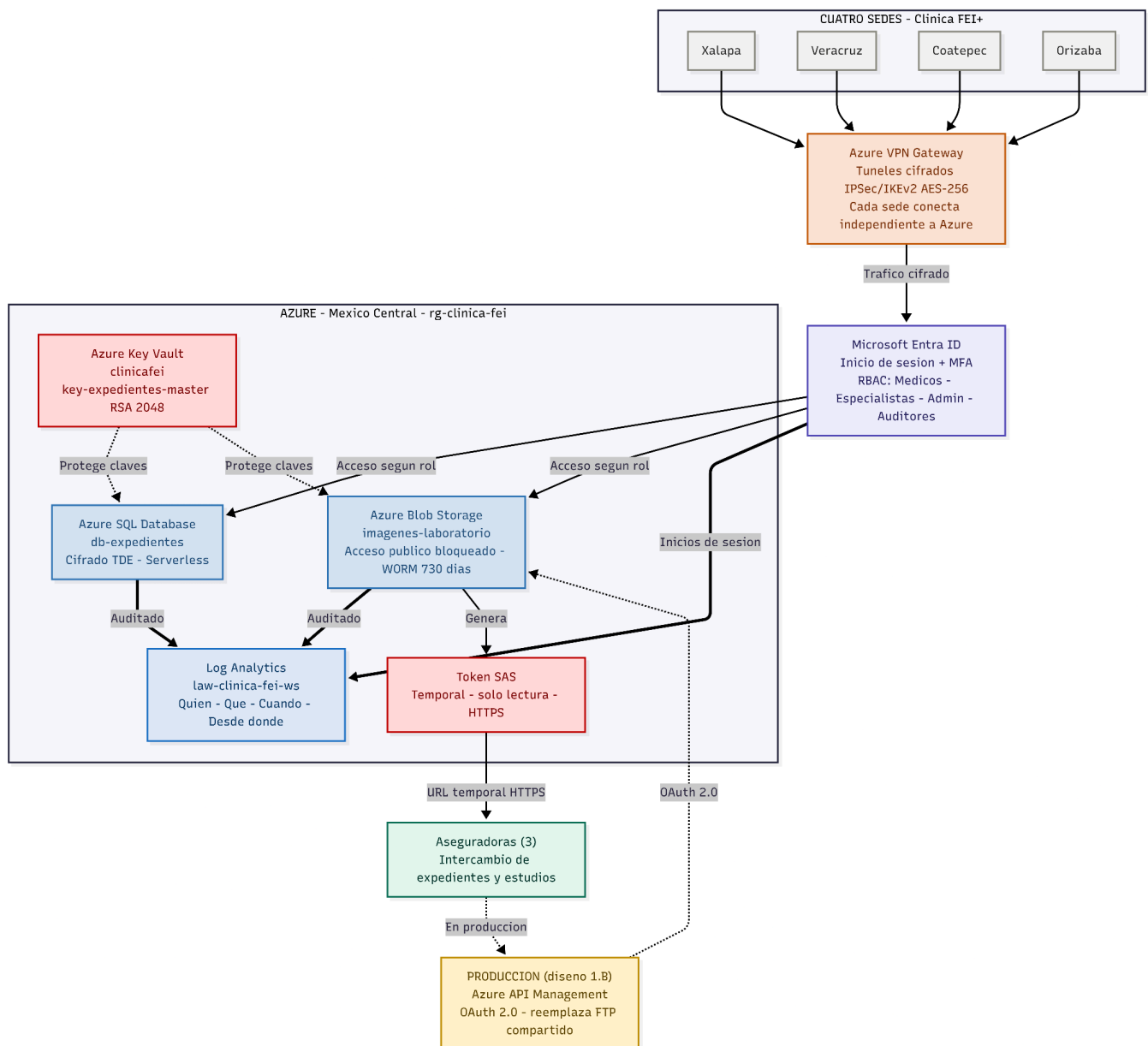
|        |           |                                                                                                                                            |                           |
|--------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|
| Fase B | Meses 2-4 | Migrar expedientes a Azure SQL MI, configurar RBAC completo, desplegar Azure Backup automatizado, configurar Sentinel                      | Resuelve R-03, R-04, R-06 |
| Fase C | Meses 4-6 | Implementar API Management para aseguradoras, capacitar técnico interno, consolidar sistemas de facturación, reemplazar WhatsApp con Teams | Resuelve R-07, R-08, R-09 |

### 3. Propuesta de Arquitectura

La arquitectura propuesta para Clínica FEI+ en Microsoft Azure sigue el modelo de Zero Trust ('nunca confies, siempre verifica') y se organiza en capas de seguridad concéntricas. Todos los componentes se despliegan en la región Azure Mexico Central para cumplir con el requisito de residencia de datos en territorio mexicano.

#### 3.1. Diagrama de Arquitectura





### 3.2. Descripción general de la arquitectura propuesta

La solución centraliza los servicios críticos de la clínica en la región Azure México Central, permitiendo que las cuatro sedes (Xalapa, Veracruz, Coatepec y Orizaba) accedan a los sistemas mediante conexiones seguras y cifradas. La arquitectura incorpora mecanismos de autenticación robusta, cifrado de datos, auditoría de accesos y un método seguro para el intercambio de información con aseguradoras.

#### Conectividad entre sedes

Las cuatro sedes de la organización se conectan a Azure mediante un Azure VPN Gateway.

Características implementadas:

- Túneles VPN Site-to-Site.
- Cifrado IPsec/IKEv2.
- Algoritmo AES-256.
- Cada sede mantiene una conexión independiente con Azure.

Esta implementación resuelve uno de los principales hallazgos de auditoría, ya que elimina la transmisión de expedientes clínicos sin cifrado entre sedes. Además, al centralizar los servicios en la nube, una falla local en una sede no afecta necesariamente la operación de las demás.

## Gestión de identidades y control de acceso

La autenticación de usuarios se realiza mediante Microsoft Entra ID.

La solución contempla:

- Inicio de sesión centralizado.
- Autenticación multifactor (MFA).
- Control de acceso basado en roles (RBAC).

Los roles definidos son:

- Médicos.
- Especialistas.
- Personal administrativo.
- Auditores.

Mediante RBAC se garantiza que cada usuario únicamente pueda acceder a la información correspondiente a sus funciones, cumpliendo con el requisito de protección de expedientes clínicos y principio de mínimo privilegio.

Por ejemplo:

- Un médico únicamente podrá consultar expedientes relacionados con sus pacientes.
- El personal administrativo no tendrá acceso a información clínica.
- Los auditores podrán consultar registros de actividad sin modificar información.

## Protección de datos almacenados

### - Azure SQL Database

Los expedientes clínicos se almacenan en una instancia de Azure SQL Database Serverless.

La base de datos utiliza:

- Transparent Data Encryption (TDE).
- Administración gestionada por Azure.
- Escalamiento automático de recursos.

El cifrado TDE protege los datos almacenados en caso de acceso físico no autorizado o robo de medios de almacenamiento.

### - Azure Blob Storage

Las imágenes médicas y estudios de laboratorio se almacenan en Azure Blob Storage.

La configuración contempla:

- Acceso público completamente bloqueado.
- Almacenamiento seguro de archivos clínicos.
- Política WORM (Write Once Read Many) durante 730 días.

La característica WORM impide la modificación o eliminación de archivos durante el periodo establecido, lo cual ayuda a cumplir con los requisitos regulatorios y de auditoría.

### - Gestión de claves criptográficas

La arquitectura incorpora Azure Key Vault para la protección de material criptográfico.

Dentro del servicio se almacena la clave maestra:

- key-expedientes-master
- RSA 2048 bits

Las claves administradas por Key Vault son utilizadas para proteger tanto:

- Azure SQL Database.
- Azure Blob Storage.

Esto permite separar la administración de claves de los servicios de almacenamiento y fortalecer la seguridad general de la plataforma.

#### - Auditoría y trazabilidad

Uno de los principales requerimientos del caso consiste en responder preguntas como:

- ¿Quién accedió?
- ¿Qué consultó?
- ¿Cuándo ocurrió?
- ¿Desde dónde se realizó el acceso?

Para ello se utiliza un espacio de trabajo de Azure Log Analytics.

Los eventos auditados incluyen:

- Accesos a la base de datos.
- Accesos a archivos clínicos.
- Inicio de sesión de usuarios.
- Uso de recursos de almacenamiento.
- Accesos mediante enlaces compartidos.

Toda esta información queda centralizada para facilitar auditorías, investigaciones de incidentes y cumplimiento normativo.

## - Intercambio seguro con aseguradoras

Actualmente la clínica utiliza un servidor FTP con credenciales compartidas, lo que representa un riesgo significativo. La propuesta sustituye este mecanismo mediante la generación de Tokens SAS (Shared Access Signature).

Características:

- Acceso temporal.
- Comunicación exclusivamente por HTTPS.
- Permisos limitados.
- Posibilidad de otorgar acceso únicamente de lectura.

Cuando una aseguradora requiere consultar un expediente o estudio médico, se genera una URL temporal firmada criptográficamente, evitando exponer la infraestructura interna de la clínica.

Este mecanismo proporciona:

- Mayor seguridad.
- Control granular de permisos.
- Trazabilidad completa de accesos.

## Evolución propuesta para producción

El diagrama contempla además una mejora futura para ambientes productivos. En lugar de depender exclusivamente de Tokens SAS, se propone implementar:

- Azure API Management.
- OAuth 2.0.

Con esta arquitectura:

- Las aseguradoras se autentican mediante estándares modernos.
- Se eliminan completamente las credenciales compartidas.
- Se reemplaza el modelo FTP heredado.

- Se obtiene control detallado sobre cada transacción realizada.

Esto facilita el cumplimiento de requisitos regulatorios y mejora significativamente la seguridad del intercambio de información.

## 4. Modelo de Responsabilidad Compartida

En el modelo de nube de Microsoft Azure (IaaS/PaaS), las responsabilidades de seguridad se distribuyen entre Azure y Clínica FEI+. Esta tabla delimita explícitamente cada control de seguridad e incluye las implicaciones regulatorias aplicables en México.

### 4.1. Tabla de Responsabilidad Compartida

| Dominio / Control                    | Responsabilidad de Azure                                                                                        | Responsabilidad de Clínica FEI+                                                        | Responsable |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|-------------|
| Seguridad física de centros de datos | Azure (100%):<br>Controles físicos, biometría, circuito cerrado, guardias 24/7 en los datacenters de Querétaro. | Ninguna. Azure asume responsabilidad total.                                            | Azure       |
| Infraestructura de red física        | Azure (100%):<br>Hardware de red, switches, routers, cables en el datacenter.                                   | Ninguna. Azure asume responsabilidad total.                                            | Azure       |
| Hipervisor y virtualización          | Azure (100%):<br>Seguridad del hipervisor, aislamiento de VMs.                                                  | Ninguna para VMs gestionadas.                                                          | Azure       |
| Sistema operativo (VMs)              | Azure gestiona el SO en servicios PaaS (SQL MI, APIM). Para IaaS: parcheo compartido.                           | Parcheo de SO en VMs IaaS si se usan. Para PaaS: ninguna.                              | Compartida  |
| Cifrado en reposo                    | Azure Key Vault gestiona claves; TDE activado en SQL MI; cifrado en Blob Storage.                               | Clínica debe habilitar el cifrado en la configuración. Azure provee la capacidad.      | Compartida  |
| Cifrado en tránsito                  | Azure fuerza TLS 1.3 en sus servicios. Azure VPN Gateway cifra tráfico site-to-site.                            | Clínica debe configurar políticas Azure que rechacen HTTP. Azure Policy lo automatiza. | Compartida  |

|                                            |                                                                            |                                                                                                                |                     |
|--------------------------------------------|----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|---------------------|
| <b>Gestión de identidades</b>              | Entra ID provee el servicio de identidades, SSO, MFA y Conditional Access. | Clínica configura políticas de acceso, crea roles, asigna usuarios, habilita MFA.                              | <b>Clínica FEI+</b> |
| <b>Control de acceso (RBAC)</b>            | Azure provee el motor de RBAC y los roles integrados.                      | Clínica define y asigna roles específicos por puesto médico. Revisión periódica de accesos.                    | <b>Clínica FEI+</b> |
| <b>Clasificación y etiquetado de datos</b> | Purview ofrece herramientas de descubrimiento y clasificación.             | Clínica debe clasificar qué datos son clínicos vs. administrativos y aplicar políticas.                        | <b>Clínica FEI+</b> |
| <b>Auditoría y logging</b>                 | Azure Monitor y Sentinel recopilan eventos automáticamente.                | Clínica configura qué eventos auditar, retención (2 años), alertas y revisiones periódicas.                    | <b>Clínica FEI+</b> |
| <b>Gestión de vulnerabilidades de apps</b> | Defender for Cloud escanea recursos Azure y da recomendaciones.            | Clínica debe aplicar las recomendaciones y parchear sus propias aplicaciones (citas, facturación).             | <b>Clínica FEI+</b> |
| <b>Respaldo de datos</b>                   | Azure Backup provee la infraestructura y motor de respaldo.                | Clínica configura políticas de backup, frecuencia, retención y realiza pruebas de restauración.                | <b>Clínica FEI+</b> |
| <b>Gestión de secretos y claves</b>        | Azure Key Vault provee el HSM y la infraestructura de gestión de claves.   | Clínica crea las claves, define las políticas de rotación y controla quién accede al Key Vault.                | <b>Clínica FEI+</b> |
| <b>Formación del personal</b>              | Ninguna.                                                                   | Clínica es 100% responsable de capacitar a sus 180 colaboradores en políticas de seguridad.                    | <b>Clínica FEI+</b> |
| <b>Consentimiento informado (LFPDPPP)</b>  | Ninguna.                                                                   | Clínica debe obtener y documentar el consentimiento de los 38,000 pacientes para tratamiento digital de datos. | <b>Clínica FEI+</b> |

## 4.2. Implicaciones Regulatorias — LFPDPPP y NOM-024-SSA3

La siguiente tabla analiza las obligaciones regulatorias aplicables a Clínica FEI+ y cómo la arquitectura Azure propuesta las atiende, delimitando la responsabilidad entre Azure y la organización.

| Obligación Regulatoria                                | Cómo lo atiende Azure                                                                                                                                                                | Responsabilidad residual de Clínica FEI+                                                                                     |
|-------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| <b>LFPDPPP — Art. 19: Medidas de seguridad</b>        | Azure Key Vault + Azure Disk Encryption garantizan cifrado. Azure Policy garantiza que ningún recurso se crea sin cifrado. Clínica debe habilitar y verificar estas configuraciones. | Azure provee la capacidad técnica; la clínica es responsable de activarla y documentarla ante el INAI.                       |
| <b>LFPDPPP — Art. 36: Transferencia de datos</b>      | Azure API Management controla y audita cada transferencia de expedientes a las aseguradoras.                                                                                         | Clínica debe firmar convenios de transmisión de datos con las aseguradoras y documentar la base legal de cada transferencia. |
| <b>NOM-024-SSA3 — Control de acceso a expedientes</b> | Entra ID + RBAC + Row-Level Security en SQL MI implementan el control de acceso por médico tratante.                                                                                 | Clínica debe implementar el proceso clínico de asignación de médico tratante y reflejarlo en los roles de Entra ID.          |
| <b>NOM-024-SSA3 — Integridad de expedientes</b>       | Azure SQL MI con auditoría de cambios (CDC) garantiza registro de modificaciones. Azure Blob Storage WORM garantiza inmutabilidad de estudios.                                       | Clínica debe definir quién puede modificar expedientes y bajo qué procesos clínicos.                                         |
| <b>NOM-024-SSA3 — Disponibilidad</b>                  | Azure SQL MI con 99.99% SLA y failover automático garantiza disponibilidad. Azure Backup provee recuperación.                                                                        | Clínica debe definir y documentar su RTO/RPO objetivo y probar el plan de recuperación periódicamente.                       |

### 4.3. Conclusión Regulatoria

Azure proporciona la infraestructura técnica necesaria para cumplir con la LFPDPPP y la NOM-024-SSA3, pero la responsabilidad jurídica ante el INAI y ante los pacientes recae en Clínica FEI+ como responsable del tratamiento de datos. Azure actúa como 'encargado' en términos del artículo 50 de la LFPDPPP, lo que debe documentarse mediante un contrato de tratamiento de datos (BAA equivalente) con Microsoft, disponible en el Microsoft Online Services Terms (OST).

La Directora de Tecnología debe garantizar que el BAA de Microsoft esté firmado antes de iniciar la migración de cualquier dato de pacientes a Azure, y que los 180 colaboradores reciban capacitación en el manejo de datos personales conforme a la LFPDPPP.

## 5. Fase de Implementación



El presente reporte documenta la implementación del entorno seguro en Microsoft Azure para el caso de la Clínica FEI+, correspondiente a la Fase 2 del proyecto final. Cada evidencia presentada se vincula directamente con uno o más de los tres hallazgos críticos detectados durante la auditoría, así como con los requisitos del negocio establecidos en la Sección 3 del caso.

5.1. Los tres hallazgos de la auditoría

Recordemos los hallazgos que pusieron en pausa la renovación del convenio con la aseguradora principal (28% de los ingresos anuales de la clínica):

| Hallazgo | Descripción                                                                              | Control implementado                                  |
|----------|------------------------------------------------------------------------------------------|-------------------------------------------------------|
| #1       | El sistema de expedientes transmite información de pacientes sin cifrado entre las sedes | Cifrado TDE + Key Vault + TLS                         |
| #2       | No existe registro de auditoría que identifique quién accedió o modificó un expediente   | Auditoría SQL + Log Analytics + Registro de actividad |
| #3       | Los estudios de laboratorio son accesibles desde cualquier computadora sin autenticación | Storage privado + MFA + grupos de acceso por rol      |

5.2 Alcance del prototipo

El entorno fue implementado con una suscripción Azure for Students dentro del control institucional de la Universidad Veracruzana. A pesar de las restricciones propias de este tipo de suscripción, se logró implementar la totalidad de los controles técnicos críticos: cifrado en reposo, gestión de claves, auditoría centralizada, bloqueo de acceso anónimo, inmutabilidad WORM, autenticación multifactor y el modelo de grupos de seguridad por rol diseñado en la propuesta de arquitectura (Entregable 1.B). Las diferencias puntuales entre el prototipo y la configuración de producción se documentan en la sección 3.1 de este reporte.

6. Evidencias de Implementación

6.1. Evidencia 1 — Grupo de recursos con la infraestructura completa

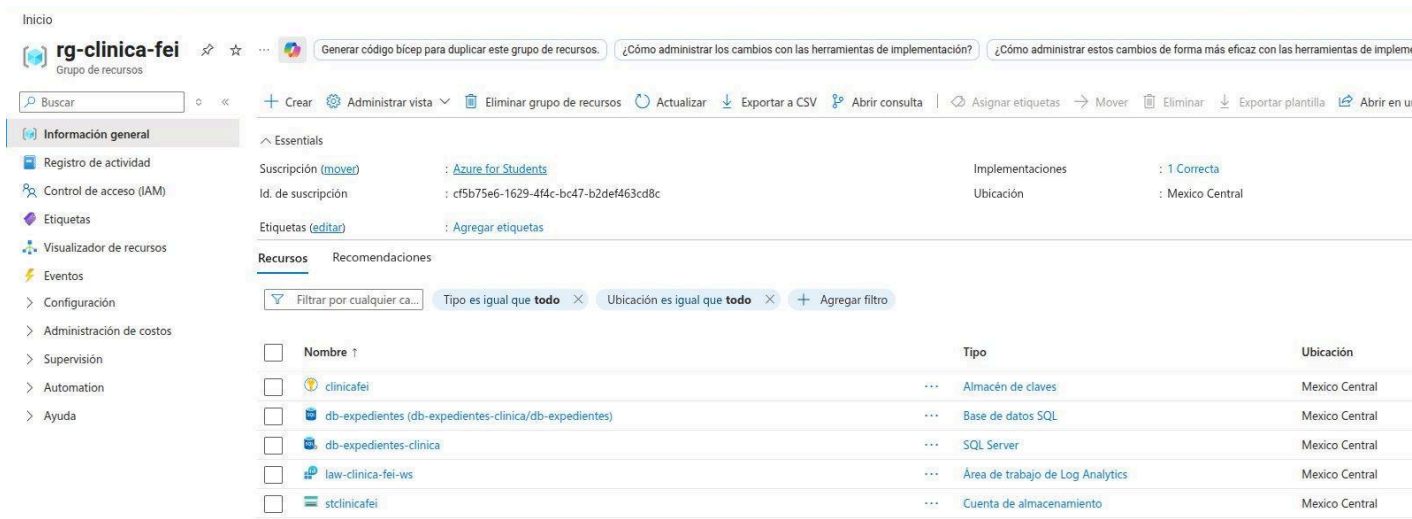


Figura 1. Grupo de recursos rg-clinica-fei con los cinco recursos desplegados en Mexico Central.

|                                  |                                                                                   |
|----------------------------------|-----------------------------------------------------------------------------------|
| Recurso de Azure                 | Grupo de recursos rg-clinica-fei                                                  |
| Control de seguridad             | Gobernanza centralizada y residencia de datos                                     |
| Hallazgo / Requisito que atiende | Restricción de residencia de datos de la aseguradora + restricción presupuestaria |
| Marco regulatorio                | Requisito contractual de la aseguradora: datos en territorio mexicano             |

¿Qué demuestra esta evidencia?

La captura muestra el grupo de recursos rg-clinica-fei conteniendo los cinco componentes de la arquitectura:

- El almacén de claves (clínicafeí)
- La base de datos SQL de expedientes (db-expedientes)
- El servidor SQL (db-expedientes-clínica)
- El área de trabajo de Log Analytics (law-clínica-fei-ws)
- La cuenta de almacenamiento (stclínicafeí).

El dato más relevante es la columna de Ubicación: los cinco recursos residen en Mexico Central, el centro de datos de Microsoft ubicado en Querétaro. Esto cumple directamente la restricción del proyecto que exige que los datos de pacientes residan en territorio mexicano, condición impuesta por la aseguradora principal. Asimismo, la suscripción visible (Azure for Students) demuestra que el prototipo

se construyó respetando la restricción presupuestaria del Director Financiero: servicios de nivel gratuito o de muy bajo costo.

Desde la perspectiva de negocio, agrupar todos los recursos en un único grupo facilita la administración para el técnico de soporte interno (perfil sin experiencia en nube): puede ver el estado de toda la infraestructura, controlar costos y aplicar permisos desde un solo lugar.

6.2. Evidencia 2 — Cifrado de datos transparente (TDE) en la base de expedientes

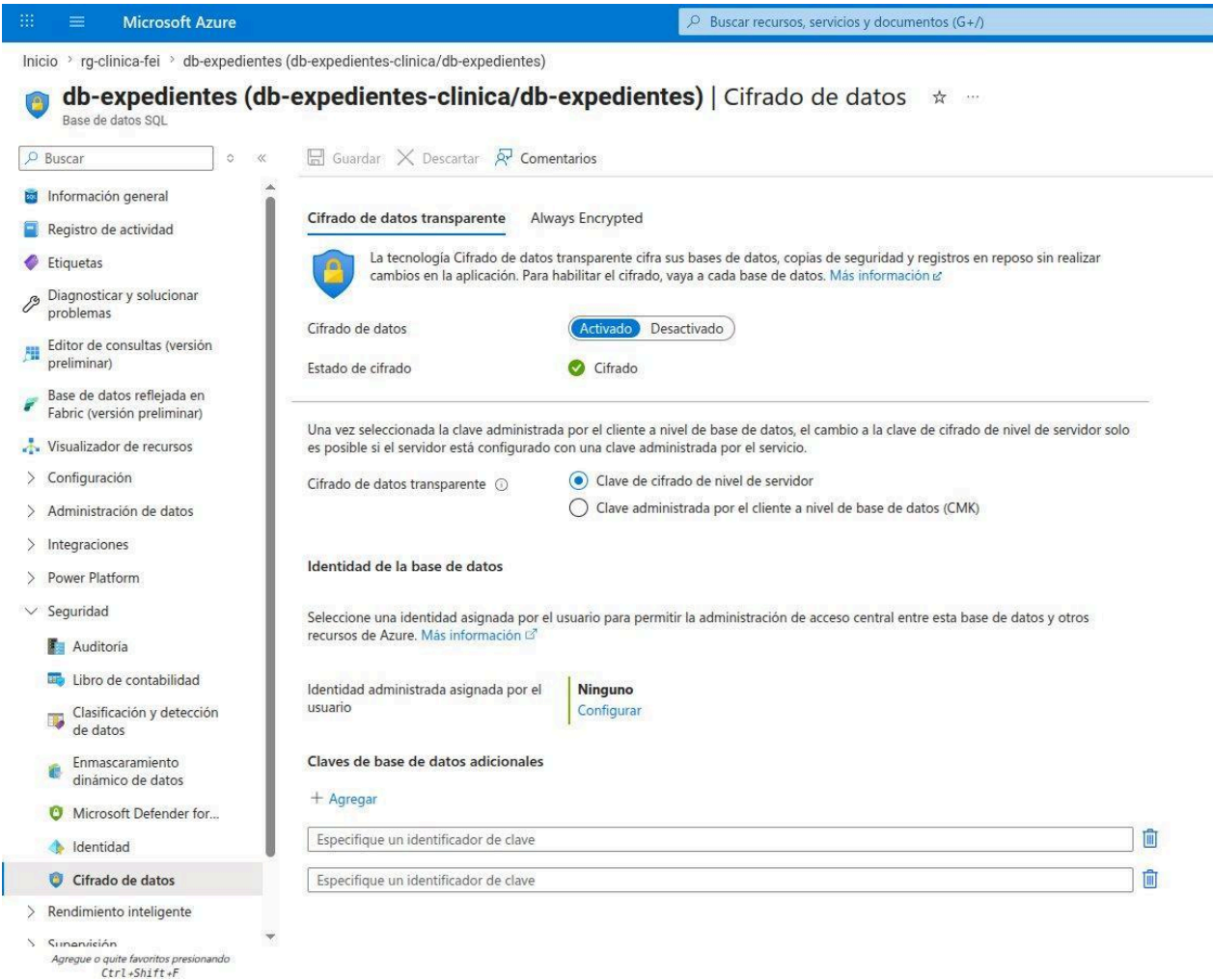


Figura 2. Cifrado de datos transparente activado en db-expedientes, estado: Cifrado.

|                                  |                                                                           |
|----------------------------------|---------------------------------------------------------------------------|
| Recurso de Azure                 | Azure SQL Database — db-expedientes                                       |
| Control de seguridad             | Cifrado en reposo (Transparent Data Encryption)                           |
| Hallazgo / Requisito que atiende | Hallazgo #1 — transmisión y almacenamiento sin cifrado ·<br>Requisito 3.4 |

**Marco regulatorio**

LFPDPPP Art. 19 (medidas de seguridad) · NOM-024-SSA3  
(protección del expediente)

**¿Qué demuestra esta evidencia?**

La pantalla de Cifrado de datos de la base db-expedientes muestra el toggle en Activado y el estado de cifrado confirmado con la marca verde Cifrado. La tecnología empleada es Transparent Data Encryption (TDE), que cifra la base de datos, sus copias de seguridad y los registros de transacciones en reposo, sin requerir cambios en las aplicaciones que la consumen.

Esto atiende directamente el Hallazgo #1 de la auditoría. En la infraestructura anterior, el servidor físico de Xalapa almacenaba y transmitía expedientes sin cifrado; con TDE, aunque un atacante obtuviera acceso físico a los discos del centro de datos o robara una copia de seguridad, los datos serían ilegibles sin la clave de cifrado. Esto también cumple el requisito de negocio 3.4: el robo físico de un equipo no debe comprometer la información de los pacientes.

La configuración utiliza la clave de cifrado de nivel de servidor administrada por Microsoft, apropiada para el prototipo. La arquitectura propuesta contempla migrar a claves administradas por el cliente (CMK) almacenadas en el Key Vault para producción, lo que daría a Clínica FEI+ control total del ciclo de vida de sus claves.

**6.3. Evidencia 3 — Almacén de claves (Azure Key Vault)**

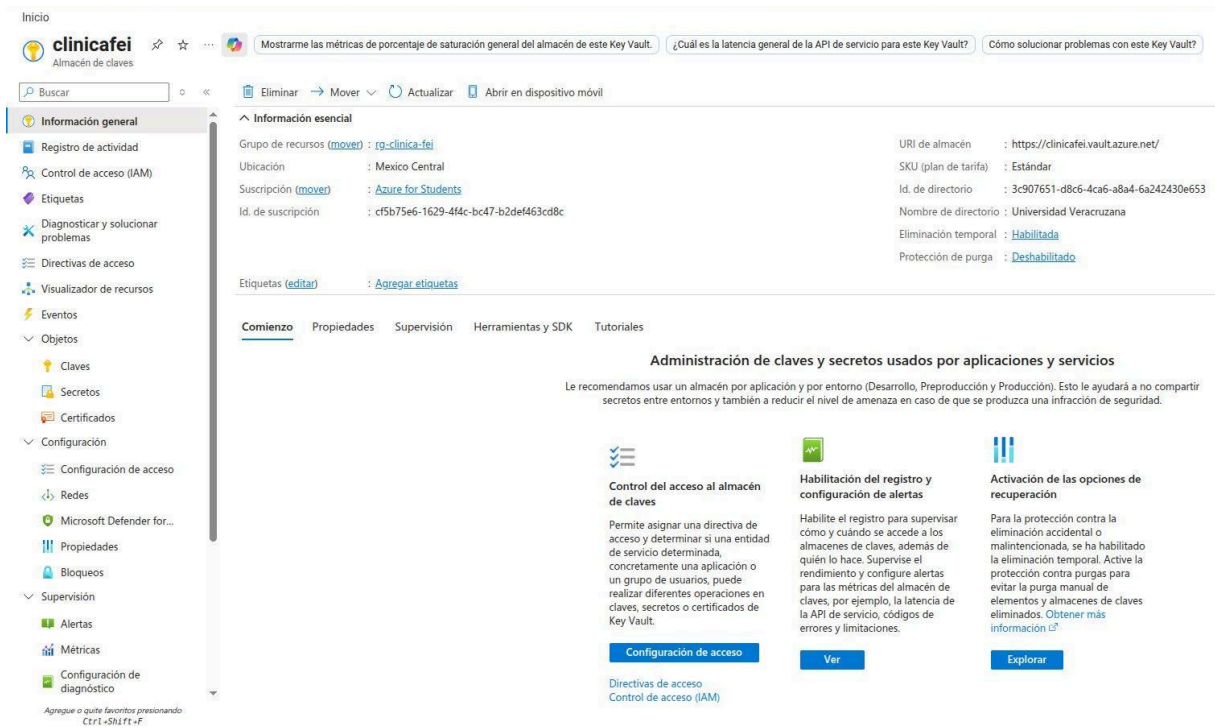


Figura 3. Key Vault clínicafei operativo en Mexico Central con eliminación temporal habilitada.

|                                  |                                                           |
|----------------------------------|-----------------------------------------------------------|
| Recurso de Azure                 | Azure Key Vault — clínicafei                              |
| Control de seguridad             | Gestión centralizada y protegida de claves de cifrado     |
| Hallazgo / Requisito que atiende | Hallazgo #1 — cifrado · Requisito 3.4 protección de datos |
| Marco regulatorio                | LFPDPPP Art. 19 — medidas de seguridad técnicas           |

¿Qué demuestra esta evidencia?

El almacén de claves clínicafei está operativo en la región Mexico Central con plan Estándar y con la característica de Eliminación temporal habilitada. Esta última es una protección crítica: si una clave se elimina por error o de forma malintencionada, puede recuperarse dentro del período de retención, evitando la pérdida irreversible de acceso a los datos cifrados.

En la arquitectura de Clínica FEI+, el Key Vault cumple la función de caja fuerte digital: las claves de cifrado nunca se almacenan junto a los datos que protegen. Esto implementa el principio de separación de funciones — quien administra la base de datos no necesariamente tiene acceso a las claves de cifrado, y cada uso de una clave queda registrado. El URI del almacén (<https://clinicafei.vault.azure.net/>) permite que las aplicaciones soliciten operaciones criptográficas sin que las claves salgan jamás del almacén.

Dentro del almacén se generó la clave RSA de 2048 bits key-expedientes-master, destinada en la arquitectura de producción al cifrado de los expedientes clínicos con claves administradas por el cliente.

6.4. Evidencia 4 — Auditoría de Azure SQL habilitada hacia Log Analytics

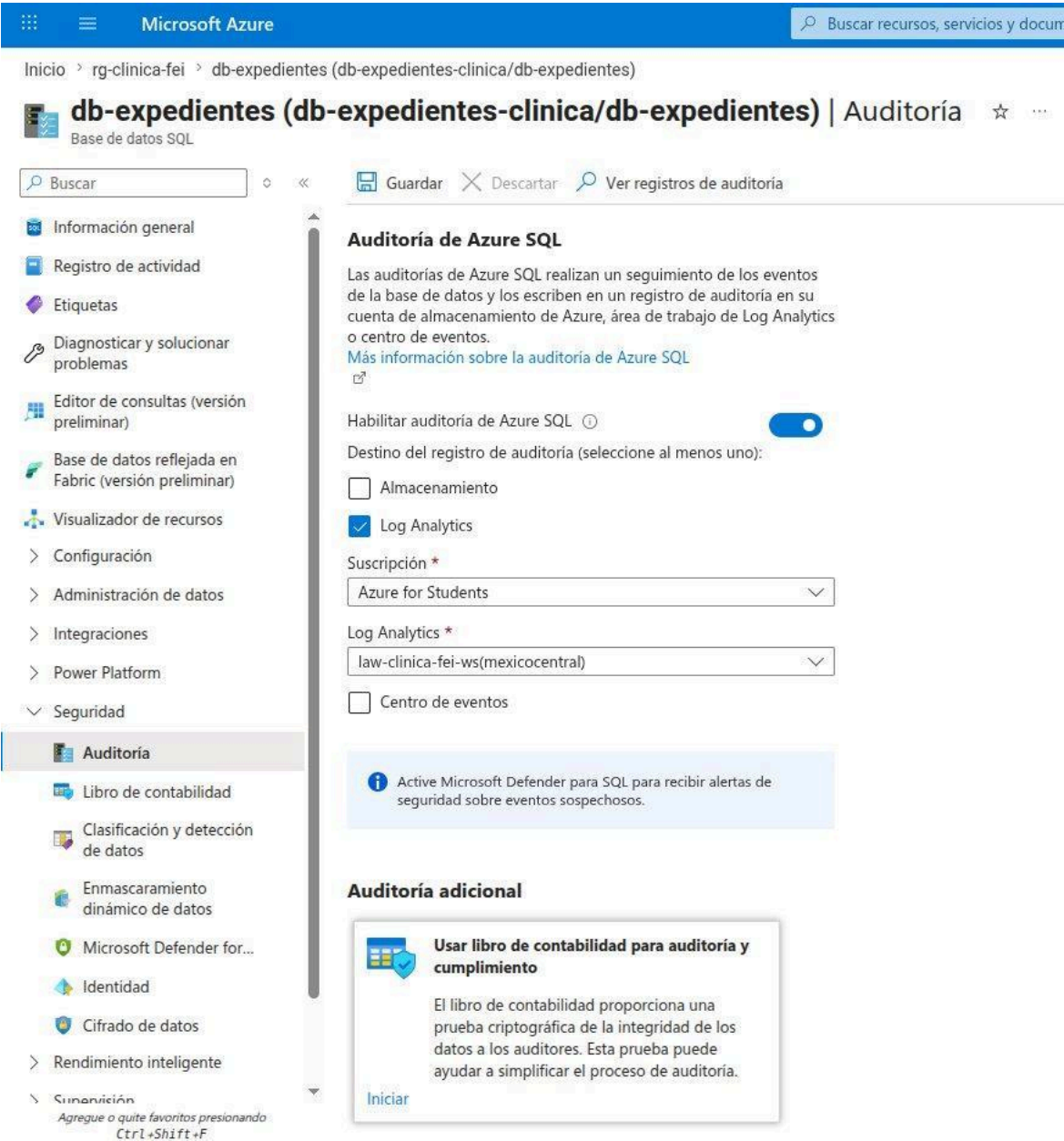


Figura 4. Auditoría de Azure SQL habilitada con destino al workspace law-clinica-fei-ws.

|                      |                                                   |
|----------------------|---------------------------------------------------|
| Recurso de Azure     | Auditoría de Azure SQL → Log Analytics            |
| Control de seguridad | Registro de auditoría de eventos de base de datos |



|                                         |                                                                              |
|-----------------------------------------|------------------------------------------------------------------------------|
| <b>Hallazgo / Requisito que atiende</b> | Hallazgo #2 — ausencia de registro de auditoría · Requisito 3.3 trazabilidad |
| <b>Marco regulatorio</b>                | NOM-024-SSA3 — registro de accesos al expediente clínico electrónico         |

### ¿Qué demuestra esta evidencia?

La auditoría de Azure SQL está habilitada (toggle activo) con destino al área de trabajo de Log Analytics law-clinica-fei-ws, en la suscripción Azure for Students. A partir de esta configuración, cada evento sobre la base de expedientes — consultas, modificaciones, intentos de acceso fallidos, cambios de permisos — se escribe automáticamente en el registro de auditoría.

Este control responde de forma directa el Hallazgo #2: antes no existía manera de saber quién accedió o modificó un expediente; ahora cada operación queda registrada con la identidad del usuario, la instrucción ejecutada, la fecha y hora, y la dirección IP de origen. Son exactamente las cuatro preguntas que la aseguradora exige poder responder ante cualquier incidente: ¿quién accedió?, ¿qué consultó o modificó?, ¿desde dónde? y ¿cuándo?

Cabe destacar que los registros se almacenan fuera de la base de datos auditada, en el workspace de Log Analytics. Esta separación impide que un usuario con privilegios sobre la base de datos pueda borrar las huellas de sus propias acciones, cumpliendo el requisito de que la trazabilidad no sea modificable por ningún usuario del sistema, ni siquiera por los administradores.

6.5. Evidencia 5 — Área de trabajo de Log Analytics operativa

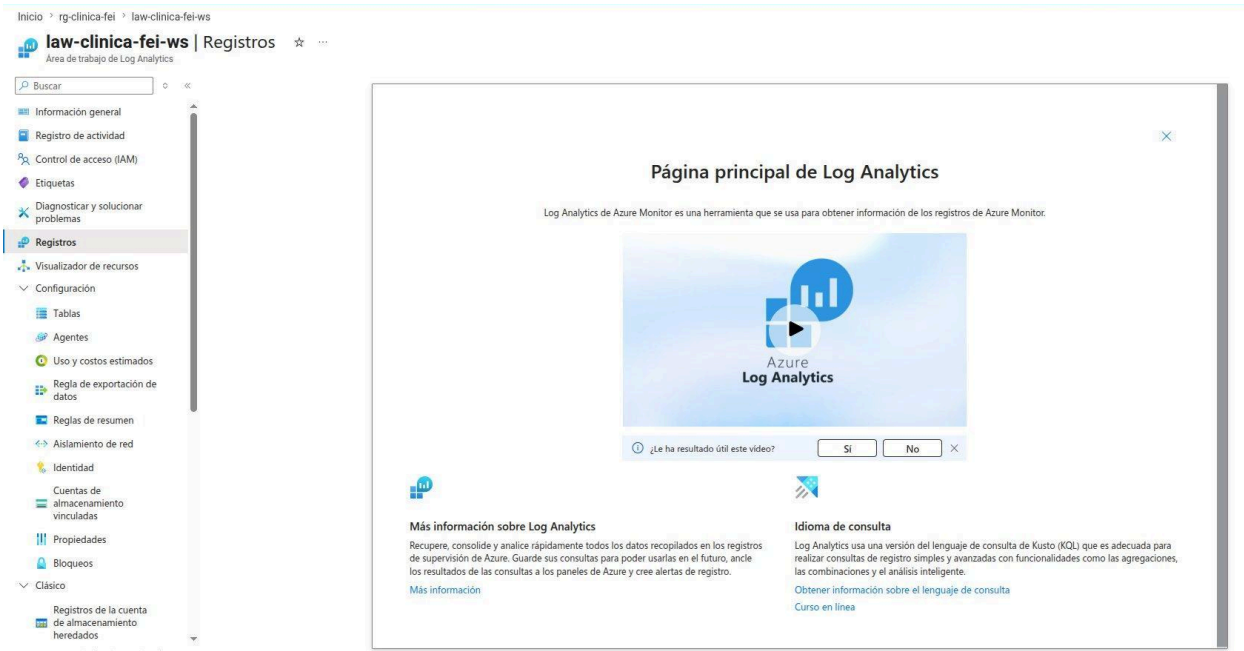


Figura 5. Workspace law-clinica-fei-ws con el módulo de Registros (KQL) disponible.

|                                  |                                                                               |
|----------------------------------|-------------------------------------------------------------------------------|
| Recurso de Azure                 | Log Analytics Workspace — law-clinica-fei-ws                                  |
| Control de seguridad             | Repositorio centralizado de registros de auditoría                            |
| Hallazgo / Requisito que atiende | Hallazgo #2 — trazabilidad · Requisito 3.3 retención de 2 años                |
| Marco regulatorio                | Requisito de la aseguradora: conservación de trazabilidad por al menos 2 años |

¿Qué demuestra esta evidencia?

El área de trabajo law-clinica-fei-ws está desplegada y operativa, con su módulo de Registros (Logs) accesible. Este workspace es el repositorio donde convergen los registros de auditoría de la base de datos SQL y, en la arquitectura completa, de todos los componentes del entorno (almacenamiento, almacén de claves, actividad administrativa).

El lenguaje de consulta Kusto (KQL), visible en la pantalla de bienvenida, permite al auditor o al responsable de seguridad ejecutar consultas precisas sobre los registros: filtrar por usuario, por rango de fechas, por tipo de operación o por dirección IP. En la demostración en vivo, esto permite responder en segundos preguntas como qué usuarios consultaron la base de expedientes durante la última semana.



En producción, la retención del workspace se configuraría a 730 días (2 años) conforme al requisito de la aseguradora. En el prototipo se utiliza la retención incluida en el nivel gratuito, documentando esta diferencia como parte de las limitaciones conocidas del entorno de demostración.

6.6. Evidencia 6 — Contenedor privado de imágenes de laboratorio

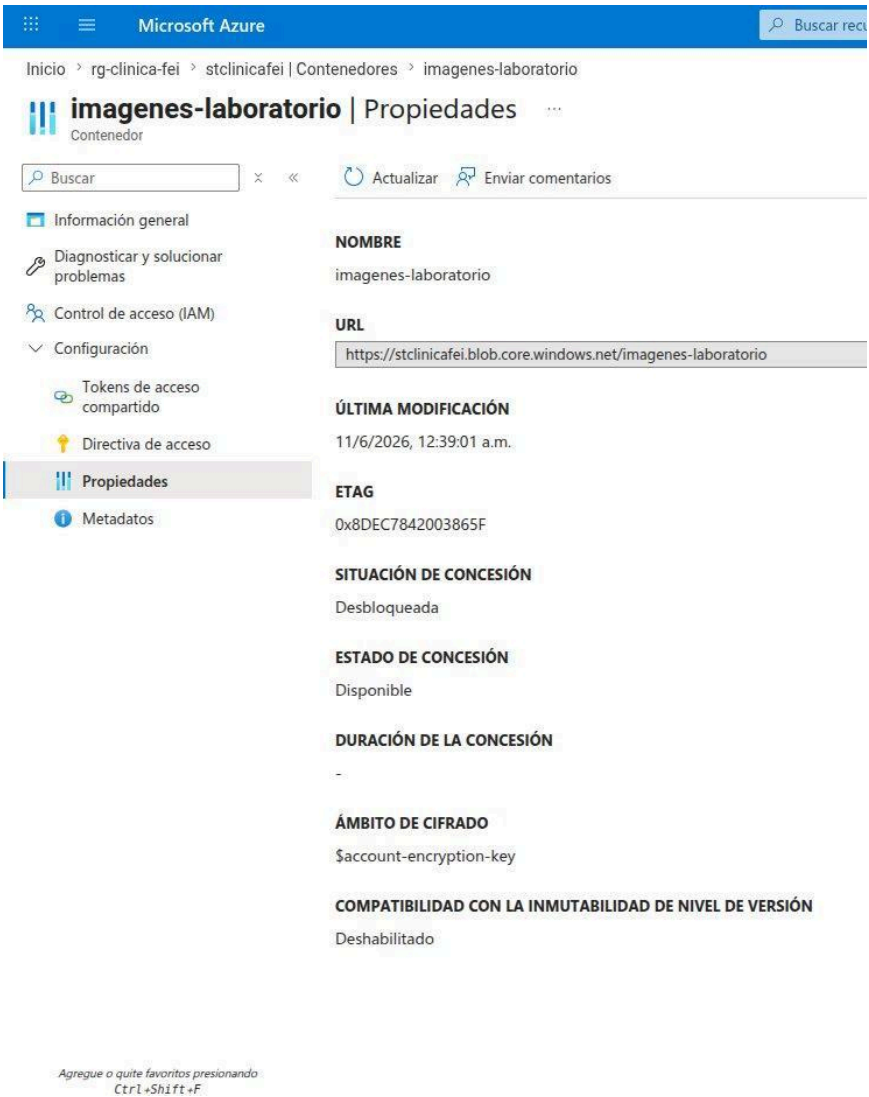


Figura 6. Propiedades del contenedor imagenes-laboratorio con cifrado de cuenta activo.

|                                  |                                                                          |
|----------------------------------|--------------------------------------------------------------------------|
| Recurso de Azure                 | Azure Blob Storage — contenedor imagenes-laboratorio                     |
| Control de seguridad             | Almacenamiento privado de estudios e imágenes médicas                    |
| Hallazgo / Requisito que atiende | Hallazgo #3 — acceso sin autenticación · Requisito 3.2 control de acceso |

|                   |                                                                |
|-------------------|----------------------------------------------------------------|
| Marco regulatorio | LFPDPPP — datos personales sensibles (salud) ·<br>NOM-024-SSA3 |
|-------------------|----------------------------------------------------------------|

¿Qué demuestra esta evidencia?

El contenedor imagenes-laboratorio existe dentro de la cuenta de almacenamiento stclinicafei y sustituye, en la arquitectura propuesta, a los tres servidores NAS de las sedes foráneas que almacenaban estudios de laboratorio accesibles desde cualquier computadora de la red interna.

La propiedad más relevante es la URL del contenedor (https://stclinicafei.blob.core.windows.net/imagenes-laboratorio), que será objeto de la prueba de acceso de la Evidencia 8. El ámbito de cifrado visible (\$account-encryption-key) confirma que todo el contenido del contenedor se cifra en reposo con la clave de la cuenta de almacenamiento — protección adicional alineada con el requisito 3.4.

6.7. Evidencia 7 — Política de inmutabilidad WORM (730 días)

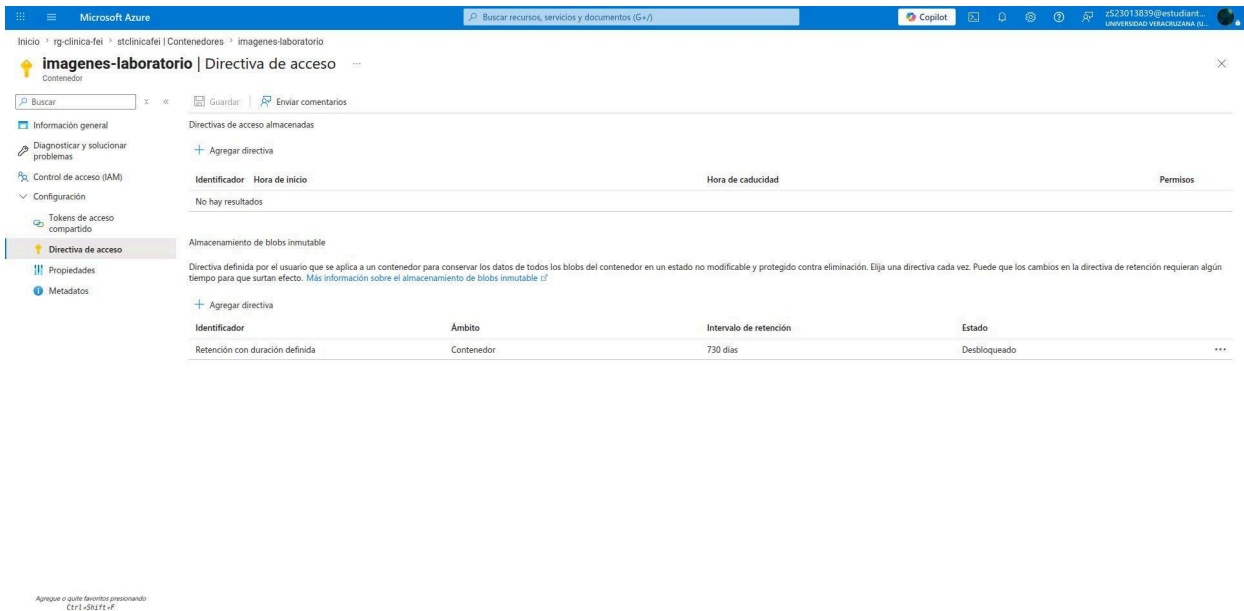


Figura 7. Directiva de retención con duración definida de 730 días sobre el contenedor.

|                                  |                                                        |
|----------------------------------|--------------------------------------------------------|
| Recurso de Azure                 | Directiva de inmutabilidad sobre imagenes-laboratorio  |
| Control de seguridad             | Almacenamiento inmutable WORM (Write Once, Read Many)  |
| Hallazgo / Requisito que atiende | Requisito 3.3 — trazabilidad no modificable por 2 años |

|                   |                                                                                        |
|-------------------|----------------------------------------------------------------------------------------|
| Marco regulatorio | Requisito de la aseguradora: registros no modificables ni siquiera por administradores |
|-------------------|----------------------------------------------------------------------------------------|

¿Qué demuestra esta evidencia?

La directiva de acceso del contenedor muestra una política de Retención con duración definida de 730 días (exactamente 2 años) con ámbito de Contenedor. Bajo esta política, cualquier archivo almacenado en imagenes-laboratorio queda protegido contra modificación y eliminación durante todo el período de retención.

Este es uno de los controles más contundentes del entorno: ni el técnico de soporte, ni el administrador de la suscripción, ni ningún usuario con privilegios puede alterar o borrar un estudio de laboratorio una vez almacenado. La inmutabilidad WORM convierte al contenedor en un archivo de evidencia confiable, que cumple literalmente la exigencia de la aseguradora de que la información de trazabilidad no debe ser modificable por ningún usuario del sistema, ni siquiera por los administradores.

El estado Desbloqueado de la política indica que el período de retención aún puede ajustarse durante la fase de pruebas; en producción, la política se bloquearía (estado Locked) para hacerla irreversible, y así se documenta en la propuesta de arquitectura.

6.8. Evidencia 8 — Prueba de acceso anónimo denegado

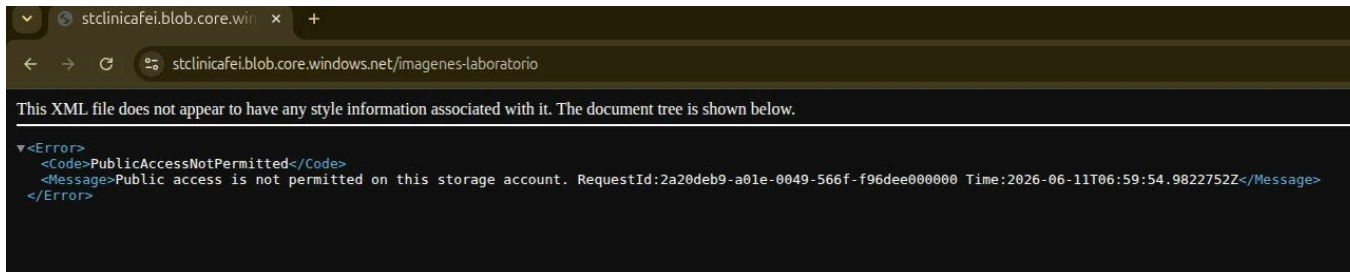


Figura 8. Error PublicAccessNotPermitted al intentar acceder al contenedor sin autenticación.

|                                  |                                                                |
|----------------------------------|----------------------------------------------------------------|
| Recurso de Azure                 | Azure Blob Storage — control de acceso público                 |
| Control de seguridad             | Bloqueo de acceso anónimo a información médica                 |
| Hallazgo / Requisito que atiende | Hallazgo #3 — estudios accesibles sin autenticación (RESUELTO) |

## Marco regulatorio

LFPDPPP Art. 19 · Requisito 3.2 — solo personal autorizado accede a información clínica

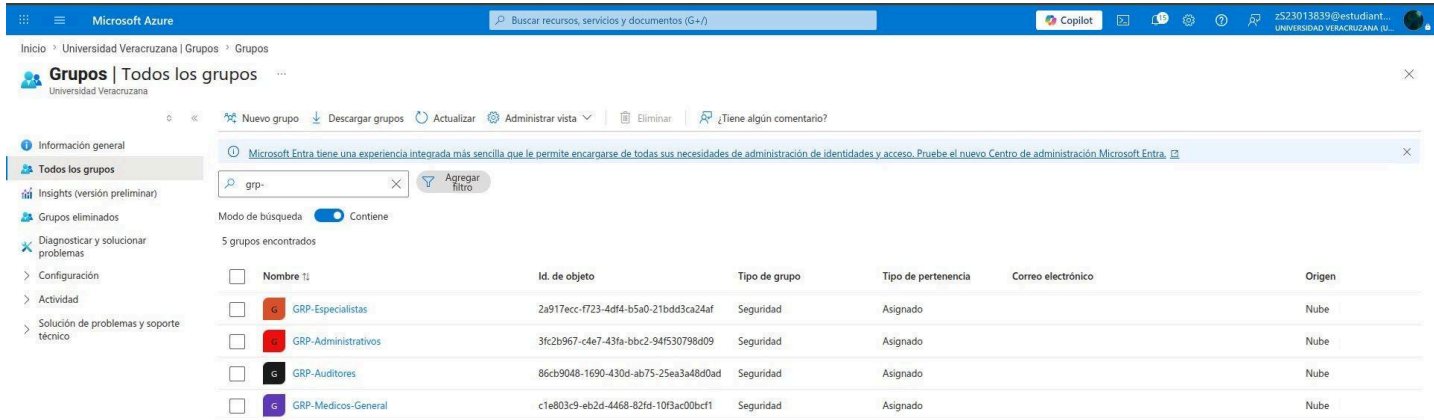
### ¿Qué demuestra esta evidencia?

Esta es la evidencia más representativa del proyecto, porque demuestra en una sola imagen la resolución del Hallazgo #3. La prueba consistió en intentar acceder a la URL del contenedor de imágenes médicas desde un navegador sin sesión autenticada — replicando exactamente el escenario que la auditoría señaló como crítico: cualquier computadora accediendo a estudios de laboratorio sin autenticación.

El resultado es el error `PublicAccessNotPermitted` con el mensaje explícito: `Public access is not permitted on this storage account`. Azure rechaza la solicitud antes de exponer cualquier contenido. La respuesta incluye además el `RequestId` y la marca de tiempo exacta de la solicitud — lo que significa que incluso este intento de acceso fallido queda registrado y es auditable.

El contraste con la situación anterior de Clínica FEI+ no puede ser más claro: donde antes los NAS de las sedes entregaban estudios de laboratorio a cualquier equipo de la red interna, ahora el acceso requiere obligatoriamente una identidad autenticada con permisos explícitos (mediante Entra ID o tokens SAS de tiempo limitado). El hallazgo que puso en riesgo el 28% de los ingresos de la clínica queda formalmente resuelto.

### 6.9. Evidencia 9 — Grupos de seguridad asignados por rol en Microsoft ID



| Nombre              | Id. de objeto                        | Tipo de grupo | Tipo de pertenencia | Correo electrónico | Origen |
|---------------------|--------------------------------------|---------------|---------------------|--------------------|--------|
| GRP-Especialistas   | 2a917ecc-f723-4d14-b5a0-21bdd3ca24af | Seguridad     | Asignado            |                    | Nube   |
| GRP-Administrativos | 3fc2b967-c4e7-43fa-bbc2-94f530798d09 | Seguridad     | Asignado            |                    | Nube   |
| GRP-Audidores       | 86cb9048-1690-430d-ab75-25ea3a48d0ad | Seguridad     | Asignado            |                    | Nube   |
| GRP-Medicos-General | c1e803c9-eb2d-4468-82fd-10f3ac00bcf1 | Seguridad     | Asignado            |                    | Nube   |

Figura 9a. Los cuatro grupos de seguridad por rol creados en Entra ID.

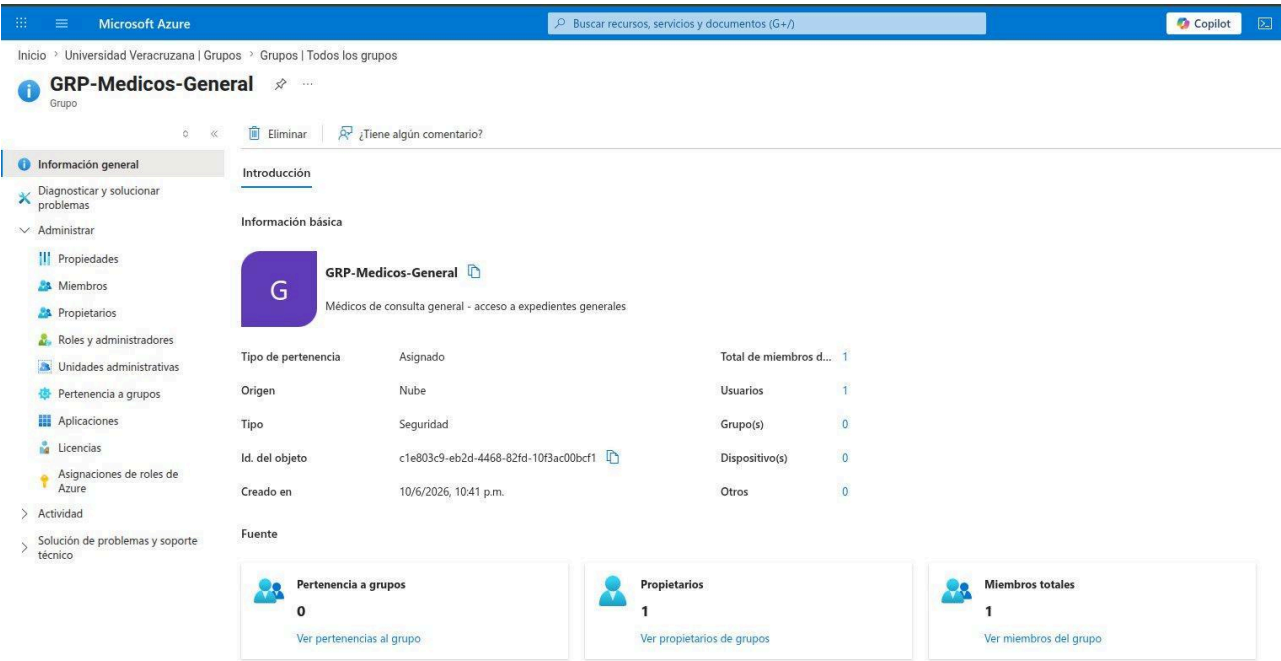


Figura 9b. Detalle del grupo GRP-Medicos-General: tipo Seguridad, origen Nube, con un miembro asignado.

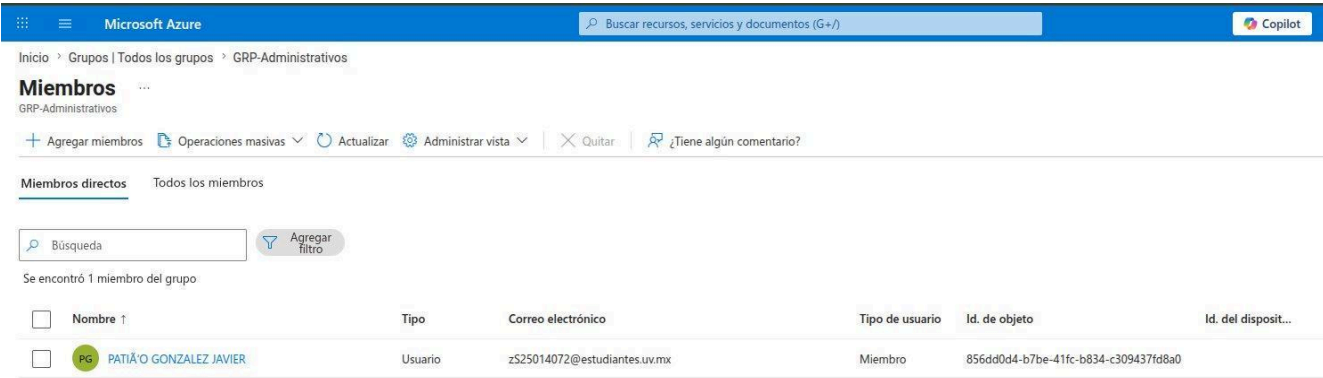


Figura 9c. Miembros del grupo GRP-Administrativos con un usuario real asignado.

|                                  |                                                                                    |
|----------------------------------|------------------------------------------------------------------------------------|
| Recurso de Azure                 | Microsoft Entra ID — grupos de seguridad                                           |
| Control de seguridad             | Modelo de control de acceso basado en roles (RBAC) por especialidad                |
| Hallazgo / Requisito que atiende | Hallazgo #3 · Requisito 3.2 — un administrativo no debe abrir expedientes clínicos |
| Marco regulatorio                | NOM-024-SSA3 — acceso restringido al médico tratante y personal autorizado         |

¿Qué demuestra esta evidencia?

Las tres capturas documentan la implementación del modelo de acceso por roles diseñado en la propuesta de arquitectura (Entregable 1.B). En el tenant de Entra ID se crearon los cuatro grupos de seguridad: GRP-Medicos-General, GRP-Especialistas, GRP-Administrativos y GRP-Audidores — todos de tipo Seguridad, con pertenencia Asignada y origen en la Nube.

El detalle del grupo GRP-Medicos-General (Figura 9b) muestra su descripción funcional — Médicos de consulta general, acceso a expedientes generales — y confirma que cuenta con un miembro asignado. La Figura 9c muestra la membresía del grupo GRP-Administrativos con un usuario real del tenant institucional, demostrando el flujo completo: creación del grupo, definición de su propósito y asignación de personas.

Este modelo materializa el requisito de negocio 3.2: los permisos no se otorgan a personas individuales sino a roles. Un médico de cardiología pertenecerá al grupo de especialistas con acceso solo a su especialidad; un administrativo pertenecerá a GRP-Administrativos, que no tiene ningún permiso sobre expedientes clínicos; un auditor podrá leer los registros sin tocar los datos. Cuando un colaborador cambia de puesto o deja la organización, basta moverlo o quitarlo del grupo — sin reconfigurar permisos recurso por recurso. En producción, estos grupos se vincularían a las asignaciones de roles de Azure (RBAC) sobre la base de datos y el almacenamiento, y a las políticas de Row-Level Security descritas en la arquitectura.

6.10. Evidencia 10 — Autenticación multifactor (MFA) en acción



Figura 10. Solicitud de aprobación MFA con número de verificación (number matching).

|                  |                                                |
|------------------|------------------------------------------------|
| Recurso de Azure | Microsoft Entra ID — autenticación multifactor |
|------------------|------------------------------------------------|

|                                         |                                                                        |
|-----------------------------------------|------------------------------------------------------------------------|
| <b>Control de seguridad</b>             | MFA con Microsoft Authenticator (number matching)                      |
| <b>Hallazgo / Requisito que atiende</b> | Hallazgo #3 — autenticación robusta · Requisito 3.2 control de acceso  |
| <b>Marco regulatorio</b>                | Mejores prácticas Zero Trust · obligatorio en Azure desde octubre 2024 |

¿Qué demuestra esta evidencia?

La captura muestra el flujo de autenticación multifactor en el acceso al entorno: tras introducir la contraseña, el sistema exige aprobar la solicitud desde la aplicación Microsoft Authenticator e introducir el número de verificación mostrado en pantalla (number matching). Sin este segundo factor, el acceso es imposible aunque la contraseña haya sido comprometida.

El mecanismo de number matching es relevante: no basta con aprobar una notificación (vulnerable a ataques de fatiga de MFA), sino que el usuario debe introducir el número exacto que aparece en la pantalla de inicio de sesión, garantizando que quien aprueba es quien realmente está iniciando sesión.

Toda la administración del entorno de Clínica FEI+ — incluida la creación de los recursos documentados en este reporte — se realizó bajo este esquema de autenticación reforzada. En producción, MFA se forzaría para los 180 colaboradores mediante directivas de acceso condicional aplicadas a los grupos de la Evidencia 9.



6.11. Evidencia 11 — Registro de actividad con trazabilidad completa

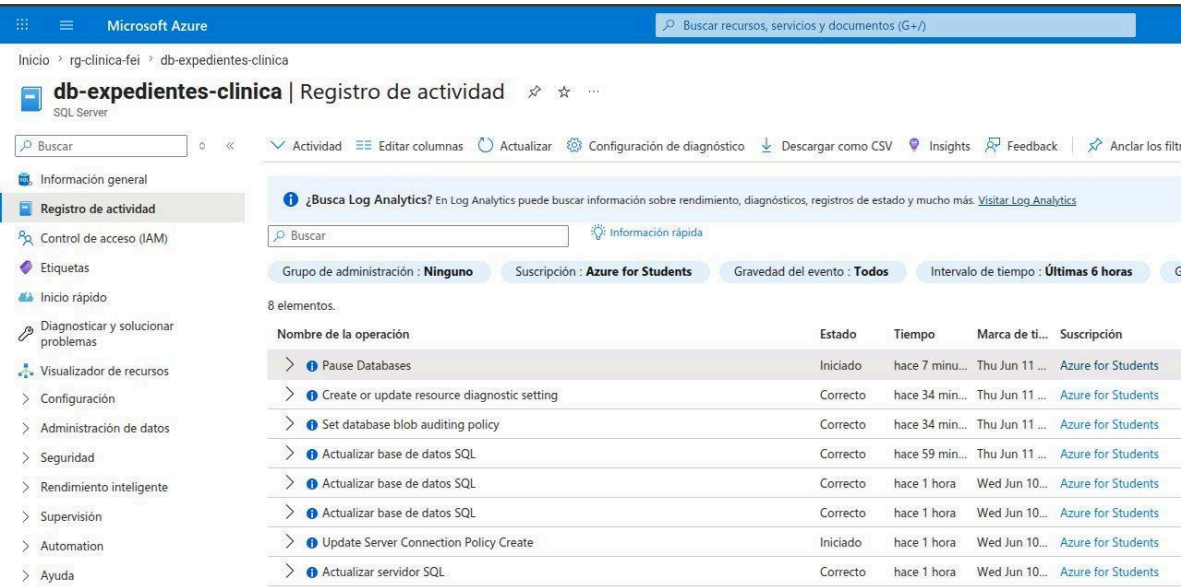


Figura 11. Registro de actividad del servidor SQL: operaciones, estado, fecha/hora y usuario iniciador.

|                                  |                                                                     |
|----------------------------------|---------------------------------------------------------------------|
| Recurso de Azure                 | Azure Activity Log — registro de actividad del servidor SQL         |
| Control de seguridad             | Trazabilidad de operaciones administrativas                         |
| Hallazgo / Requisito que atiende | Hallazgo #2 — quién, qué, cuándo (DEMOSTRADO CON DATOS REALES)      |
| Marco regulatorio                | Requisito 3.3 de la aseguradora — las cuatro preguntas de auditoría |

¿Qué demuestra esta evidencia?

Esta evidencia muestra el registro de actividad funcionando con datos reales del entorno. Se observan 8 eventos registrados, incluyendo operaciones como Set database blob auditing policy, Create or update resource diagnostic setting y varias actualizaciones de la base de datos SQL. Para cada evento, el registro documenta: el nombre de la operación, el estado (Correcto/Iniciado), el momento exacto de ejecución y — en la columna Evento iniciado por — la identidad del usuario que la realizó.

Esto es la materialización del control de trazabilidad: las preguntas de la aseguradora (¿quién accedió?, ¿qué hizo?, ¿cuándo?) tienen respuesta inmediata y verificable. Resulta especialmente significativo que el propio acto de configurar la auditoría quedó auditado — el evento Set database blob auditing policy



aparece registrado con su autor y su marca de tiempo, demostrando que ninguna acción administrativa escapa al registro.

En conjunto con la auditoría SQL (Evidencia 4) y el workspace de Log Analytics (Evidencia 5), Clínica FEI+ pasa de no tener ningún registro de auditoría a contar con trazabilidad en dos niveles: el plano administrativo (quién cambió la configuración de la infraestructura) y el plano de datos (quién consultó o modificó expedientes).

## 6.12. Evidencia 12 — Intercambio controlado con aseguradoras mediante token SAS

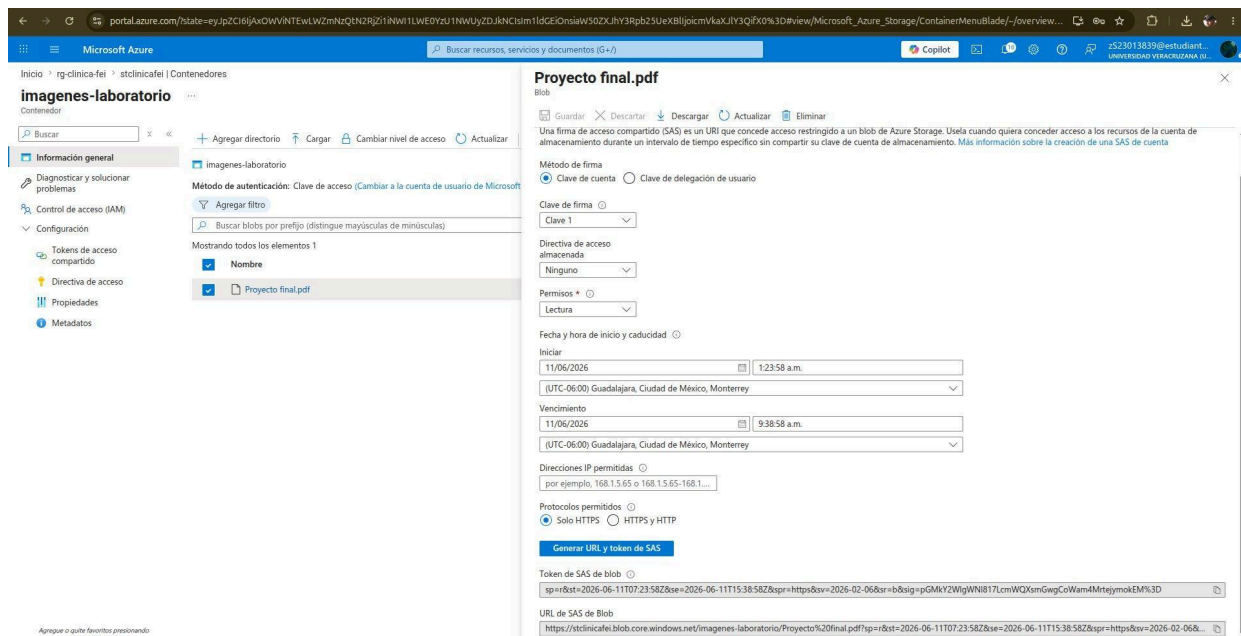


Figura 12a. Generación de un token SAS: permisos de solo lectura, solo HTTPS y expiración definida.

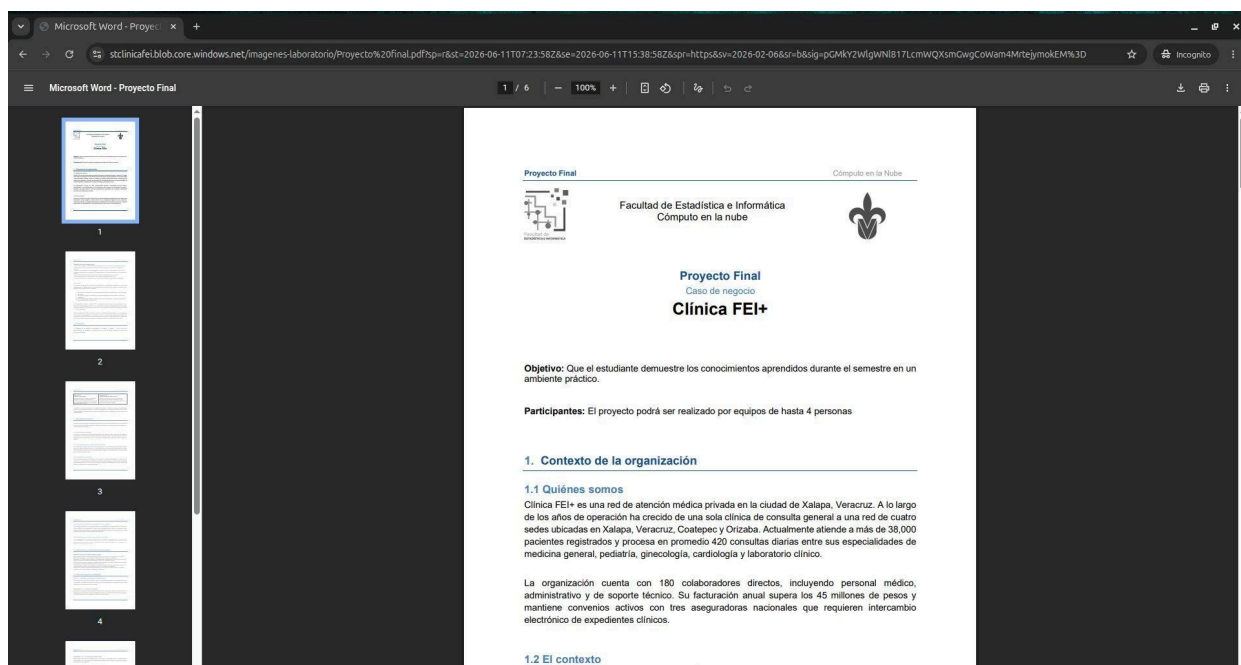


Figura 12b. Acceso exitoso al estudio desde una sesión externa usando la URL con token SAS.

|                                         |                                                                                          |
|-----------------------------------------|------------------------------------------------------------------------------------------|
| <b>Recurso de Azure</b>                 | Azure Blob Storage — Shared Access Signature (SAS)                                       |
| <b>Control de seguridad</b>             | Intercambio seguro, temporal y auditable con terceros                                    |
| <b>Hallazgo / Requisito que atiende</b> | Requisito 3.8 — integración con aseguradoras sin exponer la red interna                  |
| <b>Marco regulatorio</b>                | LFPDPPP Art. 36 (transferencia de datos) · sustituye el FTP con credenciales compartidas |

### ¿Qué demuestra esta evidencia?

Esta evidencia documenta cómo se resuelve el requisito 3.8: el mecanismo actual de Clínica FEI+ para intercambiar expedientes y resultados con las tres aseguradoras es un servidor FTP con credenciales compartidas — inseguro, sin expiración y sin trazabilidad por parte de la aseguradora. La solución implementada lo reemplaza con tokens SAS (Shared Access Signature).

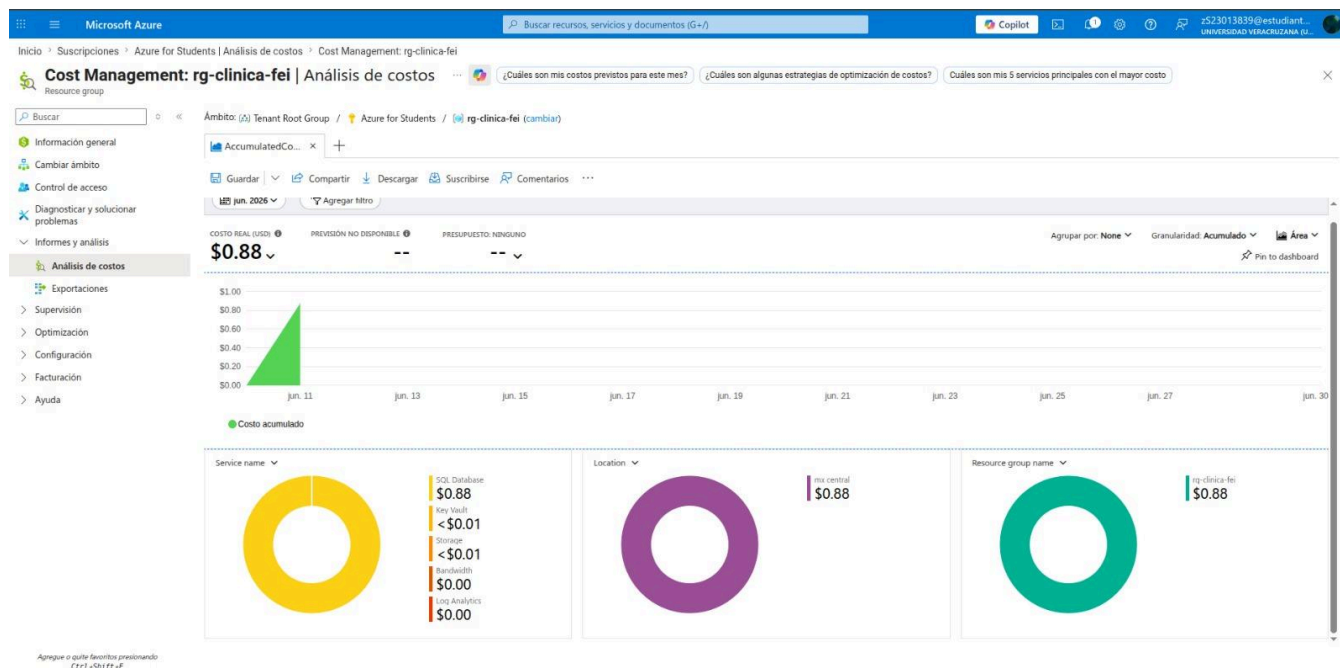
La Figura 12a muestra la generación de un token SAS sobre un estudio almacenado en el contenedor: se otorgan permisos exclusivamente de Lectura, se restringe el protocolo a Solo HTTPS, y se define una fecha y hora de vencimiento. El token resultante es una credencial firmada criptográficamente que concede acceso a un único archivo, durante una ventana de tiempo limitada y solo para lectura.

La Figura 12b prueba el acceso funcionando: desde una sesión externa (sin autenticación de la clínica), la URL que incluye el token SAS permite abrir el estudio. El contraste con la Evidencia 8 es la clave del control: sin token, el contenedor responde `PublicAccessNotPermitted`; con un token válido, de solo lectura y temporal, el acceso se concede de forma controlada. Cada parámetro del token responde a una exigencia del requisito: el permiso de lectura impide que la aseguradora modifique datos, la expiración garantiza que el acceso no sea permanente, HTTPS asegura el cifrado en tránsito, y como el acceso pasa por el endpoint del almacenamiento, la red interna de la clínica nunca queda expuesta.

Aclaración de alcance respecto al diagrama de arquitectura: el componente Azure API Management que aparece en la propuesta (Entregable 1.B) es el mecanismo recomendado para producción, donde cada aseguradora tendría credenciales OAuth 2.0 únicas y un gateway dedicado. Dado que API Management es un servicio de costo elevado no justificable para el prototipo con suscripción de estudiante, el intercambio controlado se demuestra aquí con tokens SAS, que implementan los mismos principios de

seguridad — acceso temporal, mínimo privilegio, cifrado y trazabilidad — y constituyen una solución válida y de bajo costo para esta fase.

## 6.12. Evidencia 13 — Costo de la infraestructura



## 7. Continuidad Operativa — Requisito 3.1

El requisito de negocio 3.1 establece que la clínica no puede permitirse una interrupción de más de cuatro horas en el acceso a expedientes durante horario de atención, y que la falla de una sede no debe afectar a las demás. Esta sección explica cómo la arquitectura implementada elimina el problema de raíz y documenta el comportamiento del prototipo.

### 7.1 El problema original: un servidor que no podía apagarse... y se apagaba

En la infraestructura anterior, todo dependía de un único servidor físico de 9 años de antigüedad ubicado en Xalapa. Ese servidor era un punto único de falla: si se apagaba — por falla de hardware, corte eléctrico, mantenimiento o error humano — las cuatro sedes quedaban simultáneamente sin sistema de expedientes. Con 420 consultas diarias, cada hora de caída implicaba decenas de pacientes atendidos sin acceso a su historial clínico. Mantener un servidor encendido 24/7 durante 9 años, sin redundancia y con respaldos manuales en discos externos, era un riesgo que la auditoría no podía pasar por alto (riesgo R-04 del análisis de riesgos).

## 7.2 Cómo lo resuelve Azure: ya no existe "el servidor"

La diferencia fundamental del modelo PaaS (Plataforma como Servicio) implementado es que Clínica FEI+ deja de depender de una máquina física concreta. Azure SQL Database no corre en un servidor que el técnico deba mantener encendido: corre sobre la infraestructura redundante del centro de datos de Microsoft en Querétaro, donde:

- Redundancia automática: la base de datos mantiene múltiples réplicas internas; si el nodo físico donde se ejecuta falla, Azure la mueve automáticamente a otro nodo sano en segundos, sin intervención humana.
- SLA de disponibilidad de 99.99%: Microsoft garantiza contractualmente que el servicio estará disponible — eso equivale a un máximo teórico de 52 minutos de indisponibilidad al año, muy por debajo de las 4 horas que el negocio tolera por incidente.
- Respallos automáticos continuos: Azure SQL realiza copias de seguridad completas semanales, diferenciales cada 12-24 horas y de registro de transacciones cada 5-10 minutos, con restauración a un punto en el tiempo (point-in-time restore) de los últimos 7 días. El RPO (pérdida máxima de datos) es de minutos, y la restauración está muy por debajo del RTO de 4 horas — sin que el técnico interno tenga que recordar conectar un disco duro externo.
- Independencia entre sedes: cada sede accede al servicio por internet/VPN de forma independiente; la falla de la red local de Coatepec no afecta a Xalapa, Veracruz ni Orizaba, cumpliendo la segunda parte del requisito 3.1.

## 7.3 Nota honesta del prototipo: el evento "Pause Databases"

En el Registro de actividad (Evidencia 11) se observa el evento Pause Databases. Esto merece explicación transparente: el prototipo utiliza el nivel Serverless de uso general, que pausa automáticamente la base de datos tras 1 hora de inactividad para no consumir crédito de la suscripción de estudiante — y la reanuda automáticamente en segundos al recibir la primera conexión. Este comportamiento es una decisión deliberada de optimización de costos para el entorno de demostración, coherente con la restricción presupuestaria del proyecto.

En producción, esta configuración sería diferente: se utilizaría el nivel aprovisionado (o serverless con pausa automática deshabilitada), garantizando que la base de datos de expedientes permanezca activa 24 horas al día, los 7 días de la semana. El costo de esta configuración está contemplado en la propuesta económica de producción (18,000-25,000 MXN mensuales para la arquitectura completa). La diferencia

clave respecto al servidor de Xalapa: "siempre encendido" ya no depende de un equipo físico de 9 años y de la suerte, sino de un contrato de servicio con redundancia automática.

7.4 Continuidad durante la migración: coexistencia y escritura dual

El requisito de continuidad también aplica durante la transición: la migración no puede implicar una interrupción total. La estrategia documentada en el Entregable 1.C contempla tres fases de coexistencia:

- Fase A (meses 1-2): el servidor actual sigue siendo el sistema principal mientras el entorno Azure — el que documenta este reporte — se construye y prueba en paralelo, sin tocar la operación diaria.
- Fase B (meses 2-4): se implementa escritura dual — los expedientes nuevos se crean directamente en Azure SQL mientras los históricos se migran en lotes nocturnos; la aplicación consulta ambas fuentes y presenta un resultado unificado, de modo que médicos y pacientes no perciben la transición.
- Fase C (meses 4-6): completada la migración histórica, Azure queda como sistema principal y el servidor de Xalapa pasa a respaldo temporal antes de su retiro definitivo.

En ningún punto del plan existe un "apagón" del sistema: la clínica opera de forma continua durante los seis meses del plazo otorgado por la aseguradora.

8. Matriz de Cumplimiento — Hallazgos vs. Evidencias

La siguiente matriz consolida la relación entre los hallazgos de la auditoría, los requisitos de negocio del caso y las evidencias documentadas en este reporte:

| Hallazgo / Requisito                   | Control implementado                                      | Evidencias          | Estado                         |
|----------------------------------------|-----------------------------------------------------------|---------------------|--------------------------------|
| Hallazgo #1 — Sin cifrado              | TDE en SQL + Key Vault + cifrado de Storage + TLS forzado | Evidencias 2, 3, 6  | RESUELTO — demostrable en vivo |
| Hallazgo #2 — Sin auditoría            | Auditoría SQL → Log Analytics + Registro de actividad     | Evidencias 4, 5, 11 | RESUELTO — demostrable en vivo |
| Hallazgo #3 — Acceso sin autenticación | Acceso público bloqueado + MFA + grupos de acceso por rol | Evidencias 8, 9, 10 | RESUELTO — demostrable en vivo |

|                                                                   |                                                                                                        |                          |                            |
|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|--------------------------|----------------------------|
| <b>Req. 3.1 — Continuidad (máx. 4h, sin punto único de falla)</b> | Azure SQL PaaS con SLA 99.99%, réplicas automáticas y backups continuos con restauración point-in-time | Sección 3 + Evidencia 11 | <b>RESUELTO POR DISEÑO</b> |
| <b>Req. 3.2 — Control de acceso por rol</b>                       | Grupos de seguridad por especialidad en Entra ID con miembros asignados                                | Evidencia 9              | <b>IMPLEMENTADO</b>        |
| <b>Req. 3.3 — Retención 2 años inmutable</b>                      | Política WORM de 730 días en contenedor de imágenes                                                    | Evidencia 7              | <b>IMPLEMENTADO</b>        |
| <b>Req. 3.8 — Integración controlada con aseguradoras</b>         | Tokens SAS de solo lectura, temporales y sobre HTTPS (APIM en diseño de producción)                    | Evidencia 12             | <b>IMPLEMENTADO</b>        |
| <b>Restricción — Residencia de datos en México</b>                | Todos los recursos en región Mexico Central (Querétaro)                                                | Evidencia 1              | <b>CUMPLIDO</b>            |
| <b>Restricción — Presupuesto de prototipo</b>                     | Suscripción Azure for Students, servicios de nivel gratuito                                            | Evidencia 1              | <b>CUMPLIDO</b>            |

## 8.1 Limitaciones documentadas del prototipo

En cumplimiento del criterio de evaluación que valora la documentación honesta de limitaciones, se hace constar:

- Pausa automática del nivel serverless: la base de datos del prototipo se pausa tras 1 hora de inactividad para preservar el crédito de estudiante (evento Pause Databases visible en la Evidencia 11); en producción se usaría nivel aprovisionado o pausa deshabilitada para operación 24/7, como se explica en la Sección 3.3.
- MFA por usuario: el tenant institucional de la UV no permite administrar las directivas de MFA de usuarios adicionales; el control se demuestra sobre la cuenta administradora del entorno, protegida por el servicio de autenticación institucional con number matching. En producción, MFA se forzaría a los 180 colaboradores mediante acceso condicional sobre los grupos creados.
- Vinculación RBAC: los grupos de seguridad existen y tienen miembros, pero la asignación de roles de Azure sobre los recursos (lectura de Storage, acceso a la base de datos) requiere

permisos de administración del tenant que la suscripción de estudiante no otorga; el diseño completo queda documentado en el Entregable 1.B.

- Retención de logs: el workspace usa la retención del nivel gratuito; en producción se configuraría a 730 días con costo estimado documentado en la propuesta económica.
- Política WORM en estado Desbloqueado: se mantiene así durante la fase de pruebas para permitir ajustes; en producción se bloquearía de forma irreversible.
- Lo que no se implementó (porque requiere hardware físico en cada sede): Los túneles VPN site-to-site entre las 4 sedes y Azure, no se implementó porque el VPN Gateway requiere equipos de red configurados en cada una de las cuatro sedes físicas y tiene un costo mensual considerable (~\$25-140 USD/mes según el tier). En un prototipo de estudiante no hay sedes físicas que conectar.
- El VPN Gateway no es para conectar sedes entre sí, es para que cada sede llegue a la nube de forma segura. Una vez que todos los datos están en Azure, las sedes ya no se hablan entre ellas — todas hablan con Azure. El VPN Gateway no es para conectar sedes entre sí, es para que cada sede llegue a la nube de forma segura. Una vez que todos los datos están en Azure, las sedes ya no se hablan entre ellas — todas hablan con Azure.

## 8.2 Conclusión

El entorno implementado en Microsoft Azure demuestra, con evidencia verificable en tiempo real, que los tres hallazgos críticos de la auditoría tienen solución técnica operativa: los expedientes están cifrados en reposo, cada acción queda registrada con autor y marca de tiempo, el acceso a la información médica exige autenticación multifactor y el modelo de acceso por roles está implementado con grupos de seguridad reales. Adicionalmente, la continuidad operativa que el negocio exige — sin servidor apagado, sin punto único de falla — queda resuelta por diseño al migrar de un servidor físico de 9 años a un servicio administrado con SLA de 99.99%, réplicas automáticas y respaldos continuos. La infraestructura reside íntegramente en territorio mexicano y fue construida dentro de las restricciones presupuestarias del prototipo.

Con estos controles demostrados, Clínica FEI+ está en condiciones de presentar a la aseguradora un avance tangible hacia el cumplimiento de los estándares mínimos de seguridad de la información en el sector salud, protegiendo la renovación del convenio que representa el 28% de sus ingresos anuales.